PROJECT V

Relatório de segurança

Ataques simulados contra o site da Edição Halloween

Data: 26/10/2026

Site: projectv-pec1.onrender.com

Resultado final: 50 de 50 ataques barrados, depois das correções

1. Resumo

Tentei burlar o site do jeito que um convidado curioso (ou mal-intencionado) tentaria: adiantar o relógio, desbloquear atividades antes da hora, virar outra pessoa, entrar no painel do admin, chutar links e senhas, injetar código e baixar arquivos do servidor.

- **50 ataques automáticos** contra uma cópia local idêntica ao site (mesmo código, modo produção), para não sujar os dados reais.
- **4 verificações no navegador**: código injetado nas 4 telas, relógio do celular adiantado, desbloqueio mexendo no HTML e a nova política de conteúdo.
- **Checagens no site no ar**, só de leitura: arquivos sensíveis, rotas do admin com credencial falsa e cabeçalhos de proteção.

Rodada	Barrados	Falhas	Atenção
1ª (antes das correções)	27	2 reais + 1 menor	2
2ª (depois das correções)	34	0	0
3ª (com Playlist, Caronas e Pós)	41	0	0
4ª (com Notificações)	46	0	0
5ª (Notificações v2: aparelhos, origem, envio único)	50	0	0

Na primeira rodada apareceram também duas "falhas" falsas, causadas por um teste esgotando o freio do outro. Reorganizei a ordem e confirmei que eram defesas funcionando.

2. O que foi encontrado e corrigido

#	Problema	Gravidade	Correção
1	Força bruta na senha do admin: o bloqueio só mudava a resposta, mas a senha era conferida antes. Um chute certo durante o bloqueio ainda entrava.	Alta	O bloqueio agora é conferido antes da senha. Bloqueado, nem a senha certa entra até passar o minuto.
2	O freio de tentativas era por IP. Dependendo do proxy da hospedagem, dá para forjar o IP (cabeçalho X-Forwarded-For) e ter tentativas ilimitadas.	Média	Freio geral somando todo mundo: 30 senhas erradas/min no admin e 120 códigos errados/min no site.
3	Na lista de Contribuições, a quantidade "true" era aceita como 1.	Baixa	Só aceita número de verdade, de 0 a 99.
4	A lista pública de confirmados mandava o id interno de cada convidado. Ele não dava acesso a nada.	Atenção	Removido. A lista manda só nome, monstro e se é você.
5	Não havia política de conteúdo (CSP), uma segunda tranca contra script injetado.	Atenção	CSP ativa: só roda JavaScript do próprio site. Também ativei HSTS (força HTTPS).

3. Os 50 ataques (rodada final)

Tipo	Ataque	Resultado	Detalhe
Relógio e desbloqueio	Ler o nome/descrição de atividades bloqueadas pela API	BARRADO	8 atividades bloqueadas; o servidor manda só o nome enigmático
Relógio e desbloqueio	Adiantar o relógio (cabeçalhos Date/X-Agora falsos)	BARRADO	o servidor usa só o próprio relógio; o que o celular diz é ignorado
Relógio e desbloqueio	Abrir as Previsões antes de 30/10	BARRADO	estado atual "agendada", abre 2026-10-30T04:00:00.000Z (decidido pelo servidor)
Relógio e desbloqueio	Convidado liberar uma atividade chamando a API do admin	BARRADO	respostas 401/404; estado continua bloqueado
Acesso e links	Ver a festa sem link	BARRADO	HTTP 401
Acesso e links	Trocar o id dentro do próprio token para virar outro convidado	BARRADO	HTTP 401 (assinatura HMAC não confere)
Acesso e links	Esticar a validade do token	BARRADO	HTTP 401
Acesso e links	Usar um link repassado depois que o admin gera um novo	BARRADO	código antigo e sessão aberta com ele param de funcionar na hora
Acesso e links	Trocar o próprio nome (ou outros campos) pelo perfil	BARRADO	nome continua "Atacante Souza"
Acesso e links	Descobrir o link (código) de outro convidado	BARRADO	a API pública nunca devolve códigos de convite
Acesso e links	O que a lista pública de confirmados expõe	BARRADO	campos: avatar, nome, souEu
Painel admin	Usar rotas do admin sem senha, com token de convidado ou token forjado	BARRADO	7 rotas × 4 credenciais falsas: todas 401
Painel admin	Descobrir a senha pelo tempo de resposta	BARRADO	comparação em tempo constante (crypto.timingSafeEqual)
Painel admin	Ler dados abrindo o HTML do /admin sem login	BARRADO	a página é só a casca; os dados vêm da API protegida
Contribuições	Apagar a contribuição de outra pessoa	BARRADO	2 tentativas, 0 funcionaram
Contribuições	Quantidades absurdas (negativas, gigantes, texto)	BARRADO	todas recusadas (0 a 99)
Contribuições	Inundar a lista com mudanças (spam)	BARRADO	freio de 40 mudanças por minuto por convidado
Injeção de código	XSS: nome/bebida com HTML e <script>	BARRADO	dados guardados como texto (HTTP 200); todas as telas escapam o texto antes de mostrar — conferido no navegador abaixo
Injeção de código	SQL injection no código e nos textos	BARRADO	todas as consultas usam parâmetros; banco intacto (4 convidados)
Injeção de código	JSON quebrado para provocar erro	BARRADO	HTTP 400, sem detalhes internos na resposta
Injeção de código	Corpo gigante (200 KB) para travar o servidor	BARRADO	HTTP 413, limite de 32 KB

Tipo	Ataque	Resultado	Detalhe
Arquivos do servidor	Baixar código, banco ou segredos pelo navegador	BARRADO	10 caminhos testados, nenhum expõe arquivo interno
Tempo real (Socket.IO)	Conectar sem credencial ou se passar de telão/admin	BARRADO	todas recusadas
Tempo real (Socket.IO)	Mandar eventos falsos pelo socket (liberar, entrar na sala do admin)	BARRADO	o servidor só escuta o evento "hora"; o resto é ignorado
Tempo real (Socket.IO)	Convidado receber dados do admin pelo socket	BARRADO	convidados só recebem o aviso "atualizar", sem dados
Proteções do navegador	Página dentro de iframe de outro site (clickjacking)	BARRADO	X-Frame-Options: DENY
Proteções do navegador	Link de convite vazar para outros sites (Referer)	BARRADO	Referrer-Policy: no-referrer
Proteções do navegador	Política de conteúdo (CSP) contra scripts injetados	BARRADO	CSP ativa
Proteções do navegador	CORS: outro site ler a API com o login do convidado	BARRADO	a API não libera outras origens; o login vai em cabeçalho, não em cookie (sem CSRF)
Playlist, caronas e pós	Votar no pós antes das 23h (ou ver as opções antes)	BARRADO	HTTP 403; antes de abrir o servidor não manda nem as opções
Playlist, caronas e pós	Apagar a música que outra pessoa sugeriu	BARRADO	HTTP 404
Playlist, caronas e pós	Votar várias vezes na mesma música	BARRADO	5 votos enviados, 1 contado
Playlist, caronas e pós	Sugerir mais de 5 músicas	BARRADO	8 tentativas, 5 aceitas
Playlist, caronas e pós	Lotar um carro além das vagas (3 pessoas ao mesmo tempo, 1 vaga)	BARRADO	1 entrou
Playlist, caronas e pós	Cancelar a carona de outra pessoa	BARRADO	HTTP 404; carro continua lá
Playlist, caronas e pós	Oferecer 999 vagas	BARRADO	HTTP 400 (limite de 1 a 6)
Notificações	Cadastrar endereço falso para o servidor fazer requisições (SSRF)	BARRADO	6 endereços (rede interna, metadados, outro site): 0 aceitos; só serviços de push oficiais passam
Notificações	Convidado mandar notificação para todo mundo	BARRADO	HTTP 401
Notificações	Inscrever aparelho sem estar logado	BARRADO	HTTP 401
Notificações	Encher o servidor de inscrições (8 aparelhos para a mesma pessoa)	BARRADO	5 guardados; do 6º em diante o servidor recusa (limite de 5 por pessoa)
Notificações	Desligar os avisos do celular de outra pessoa	BARRADO	HTTP 404; os 5 aparelhos dela continuam
Notificações	Disparar notificação de teste no celular de outra pessoa	BARRADO	HTTP 404
Notificações	Mandar o mesmo aviso 3 vezes (clique repetido / requisição reenviada)	BARRADO	1 envio de fato; os outros foram ignorados

Tipo	Ataque	Resultado	Detalhe
Notificações	Outro site disparar ação no Project V pelo navegador do convidado	BARRADO	HTTP 403 (origem conferida)
Notificações	Usar o manifesto do atalho para ler arquivos	BARRADO	HTTP 404
Força bruta	Chutar códigos de convite (40 tentativas)	BARRADO	24 bloqueadas pelo freio; espaço de 31^10 ≈ 8×10^14 códigos (bilhões de anos a 20 por minuto)
Força bruta	Chutar códigos trocando o IP a cada tentativa (X-Forwarded-For)	BARRADO	200 tentativas com IPs falsos: 100 passaram e o resto foi barrado pelo freio geral (teto de 120 erros/min no site todo). Nesse ritmo, achar um código levaria bilhões de anos
Força bruta	Força bruta na senha do admin	BARRADO	freio após 8 erros por minuto
Força bruta	Força bruta na senha do admin trocando o IP a cada chute	BARRADO	60 chutes com IPs falsos: 22 conferidos, o resto barrado (teto de 30 erros/min no site todo). Com uma senha forte (16+ caracteres aleatórios) isso é impossível de quebrar
Força bruta	Acertar a senha durante o bloqueio (o chute certo vale?)	BARRADO	HTTP 429: bloqueado, nem a senha certa é aceita até passar o minuto

4. Verificações no navegador

Teste	Resultado
Nome de convidado e bebida com código malicioso (<img onerror>, <svg onload>), aberto nas telas do convidado, Contribuições, admin e telão	Nenhum código executou nas 4 telas. Tudo aparece como texto.
Relógio do celular adiantado para 1º de novembro	A contagem continuou mostrando 7 dias (relógio do servidor) e os 7 cadeados continuaram fechados.
Desbloquear os cards mexendo no HTML pelo console	O card muda de cor, mas continua mostrando só o nome enigmático. O conteúdo real nunca chega ao celular antes da hora.
Política de conteúdo (CSP) nova	Nenhuma tela quebrou e não houve nenhum bloqueio indevido no console.

5. Site no ar (somente leitura)

- 8 caminhos sensíveis (`/package.json`, `/.env`, código do servidor, banco, `.git`, dependências, `../`): todos 404.
- 5 rotas (festa, perfil, estado do admin, backup, contribuições) com token forjado: todas 401.
- SQL injection no código do convite: recusado (404).
- Cabeçalhos: anti-iframe e anti-vazamento do link ativos, sem CORS aberto, sem cache longo.
- A CSP e as correções da seção 2 entram no ar depois do próximo **git push**.

6. O que depende de você

- **Senha do admin forte** (variável `ADMIN_SEGREDO` no Render): 16 caracteres ou mais, aleatórios. Com o freio de 30 chutes por minuto, uma senha assim não cai nunca. Uma senha curta ou óbvia é o ponto mais fraco que sobra.
- **Não compartilhe a senha do admin.** O telão usa a mesma senha: depois da festa, clique em Sair no notebook.
- **O link é a chave.** Quem tiver o link entra como aquela pessoa. Se alguém repassar, use "Novo link" no admin: o antigo para na hora.
- **Baixe um backup** no admin antes de mandar os links e antes de abrir os portões.
- **Suba as correções:** `git add -A`, `git commit`, `git push`.

7. Limites deste teste

- Nenhum teste garante 100%. Ele cobre os ataques realistas para um site de festa entre amigos.
- Não testei as contas do Render, do Turso e do GitHub. A segurança delas depende das suas senhas e da verificação em duas etapas.
- Não consegui medir, de fora, como o proxy do Render trata o IP forjado. O freio geral resolve isso de qualquer jeito.
- Cada jogo novo (Previsões, Maldição, Monstro…) cria rotas novas. A bateria vai ganhar ataques específicos para cada um, principalmente para os papéis secretos do Monstro e o autor anônimo do Correio.

Para rodar a bateria de novo:

```
npm run seguranca
```